

TechNova Solutions

123 Heath
Lisco, ST 12345
(123) 456 - 7890

GOVERNANCE, RISK, AND COMPLIANCE (GRC) ASSESSMENT REPORT

Cybersecurity Risk Assessment and Recommendations for TechNova Solutions Prepared Using
ISO/IEC 27001 Information Security Management System (ISMS) Framework Prepared for:
TechNova Solutions A Fictional Software Development Company

Prepared by: Samuel Chukwudi Nweke

Course: Governance, Risk, and Compliance

Project Title: Initial Governance, Risk, and Compliance (GRC) Assessment and Ransomware
Incident Response Plan Submitted

To: Glory Odeli

Date of Submission: 31 July 2026

Confidentiality Statement

This report contains a fictional cybersecurity assessment prepared solely for academic purposes. TechNova Solutions is a fictional organization created for this assignment. The report demonstrates the application of Governance, Risk, and Compliance (GRC) principles based on the ISO/IEC 27001 framework and should not be interpreted as an assessment of any real organization. The next section is the Table of Contents

Table of Contents

Understanding the Business

Asset Register

Risk Register

Security Controls

Policies

Compliance Review

Audit Checklist

Executive Summary

Conclusion

Understand the Business

What the Company Does

TechNova Solutions is a fictional technology company with approximately 50 employees. It develops and maintains web and mobile applications for customers. Employees work both remotely and from the office, using Microsoft 365 for email and document storage and GitHub for source-code management.

What Information Is Most Valuable

The company's most valuable information includes **customer personal and payment information**, such as names, email addresses, phone numbers, and payment-related data. Its **source code, application designs, credentials, business documents, and Microsoft 365/GitHub accounts** are also highly valuable because they support the company's operations and intellectual property. Protecting this information is essential for maintaining customer trust and business continuity.

Who Could Be Interested in Attacking the Company

Potential attackers include **cybercriminals seeking financial gain**, particularly through phishing, ransomware, credential theft, or payment-related fraud. Attackers may also target the company to steal customer information or proprietary source code. Compromised employee accounts could provide access to Microsoft 365, GitHub, or internal systems. Because employees work remotely, attackers may also exploit unsecured devices, networks, or weak authentication.

Why Cybersecurity Matters to This Business

Cybersecurity is critical because TechNova handles sensitive customer information and develops software that customers depend on. A security incident could result in **data breaches, financial losses, service disruption, reputational damage, legal or regulatory consequences, and loss of customer trust**. With no dedicated security team and no previous formal risk assessment, the company may have unidentified security gaps. Strengthening cybersecurity will reduce these risks and help demonstrate to the prospective enterprise customer that TechNova has appropriate controls for protecting information and business operations.

Asset ID	Asset Name	Asset Owner	Description / Im	Category	Criticality	Status	Location / Syste	Notes			
AST-001	Customer Database	Operations Manager	Stores customer information	Information Asset	High	Active	Database Server	Contains sensitive customer information.			
AST-002	Employee Laptop	IT Administrator	Used by employees	Hardware	High	Active	Office / Remote	Assigned to employees.			
AST-003	GitHub Repository	Development Team	Contains the company code	Software / Source	High	Active	GitHub Cloud	Enable MFA and access controls.			
AST-004	Microsoft 365	IT Administrator	Provides email, calendar, etc.	Cloud Service	High	Active	Microsoft 365 Tenant	Includes Exchange, OneDrive, Teams, and SharePoint.			
AST-005	Internet Connectivity	IT Administrator	Enables access to external resources	Network Infrastructure	High	Active	Office Network	Business-critical connectivity.			
AST-006	Human Resource System	Human Resources	Stores confidential employee data	Information Asset	High	Active	HR System / Secure	Contains confidential employee data.			
AST-007	Payment System	Finance Manager	Processes customer payments	Application / Financial	High	Active	Payment Platform	Subject to financial and regulatory controls.			
AST-008	Company Website	Web Developer	Serves as the primary public interface	Web Application	Medium	Active	Web Hosting Platform	Public-facing business website.			
AST-009	Cloud Storage	IT Administrator	Stores company documents	Cloud Storage	High	Active	Cloud Platform	Regular backups and access monitoring required.			
AST-010	Employee User Accounts	IT Administrator	Provide authentication and access	Identity & Access	High	Active	Active Directory / IdP	Protected with strong authentication and least-privilege access.			

Risk ID	Risk Description	Threat	Vulnerability	Likelihood	Impact	Risk Rating	Risk Owner	Proposed Mitigation	Status	Review Date
RISK-001	Ransomware encryption	Ransomware attack	Lack of endpoint protection	High	High	High	IT Administrator	Deploy endpoint protection	Open	TBD
RISK-002	Phishing attack	Phishing emails	Employees lack awareness	High	High	High	IT Administrator	Implement advanced email filtering	Open	TBD
RISK-003	Unauthorized access	Stolen or weak credentials	Weak passwords	High	High	High	IT Administrator	Enforce strong password policy	Open	TBD
RISK-004	Source code theft	Credential compromise	Excessive user permissions	Medium	High	High	Development Team	Apply role-based access control	Open	TBD
RISK-005	Customer database breach	External cyberattack	Inadequate application security	Medium	High	High	Operations Manager	Use secure coding practices	Open	TBD
RISK-006	Data loss due to hardware failure	Hardware malfunction	No tested backup strategy	Medium	High	High	IT Administrator	Implement automated backup	Open	TBD
RISK-007	Insider misuse of data	Malicious or negligent employee	Excessive user permissions	Medium	High	High	Human Resources	Enforce least-privilege principle	Open	TBD
RISK-008	Remote worker device compromise	Malware or device theft	Unsecured personal devices	High	Medium	High	IT Administrator	Require company-managed devices	Open	TBD
RISK-009	Website defacement	Web application vulnerability	Outdated software	Medium	Medium	Medium	Web Development	Apply timely security patches	Open	TBD
RISK-010	Loss of confidential information	Unauthorized access	Poor access control	Medium	High	High	Human Resources	Restrict access to sensitive data	Open	TBD

Security Controls

Security Controls Security controls are safeguards implemented to reduce cybersecurity risks and protect the confidentiality, integrity, and availability of TechNova Solutions' information assets. Based on the identified risks and ISO/IEC 27001 principles, this assessment recommends 15 controls divided into three categories: Preventive Controls, Detective Controls, and Corrective Controls.

1. Preventive Controls: Preventive controls are designed to stop security incidents from occurring by reducing vulnerabilities, restricting unauthorized access, and improving security awareness.

Control	Why This Control Is Useful
1. Multi-Factor Authentication (MFA)	MFA requires users to provide additional verification beyond a password. It reduces the risk of unauthorized access if employee passwords are stolen through phishing or other attacks. This is especially important for Microsoft 365 and GitHub accounts that contain sensitive company information.
2. Role-Based Access Control (RBAC)	RBAC ensures employees only access information and systems required for their job roles. It reduces the risk of accidental data exposure, insider threats, and unauthorized access to sensitive customer or company information.
3. Security Awareness Training	Regular employee training helps staff recognize phishing emails, ransomware attempts, social engineering attacks, and unsafe security practices. Since employees are often targeted by attackers, awareness training reduces human-related security risks.
4. Endpoint Protection and Endpoint Detection & Response (EDR)	EDR software protects employee laptops by detecting and blocking malware, ransomware, and suspicious activities. It is useful because TechNova employees work remotely and from offices, increasing the number of devices that could be attacked.
5. Data Encryption	Encryption protects sensitive information by converting data into an unreadable format for unauthorized users. It helps protect customer payment information, employee records, and confidential company documents if data is stolen or exposed.

2. Detective Controls: Detective controls identify security incidents, suspicious activities, and vulnerabilities after or while they occur, allowing faster investigation and response.

Control	Why This Control Is Useful
1. Security Monitoring and Logging	Collecting logs from Microsoft 365, GitHub, servers, and applications helps identify unusual behavior, unauthorized access attempts, and possible security breaches. Logs also provide evidence during investigations.
2. Vulnerability Scanning	Regular vulnerability scans identify weaknesses such as outdated software, missing security patches, and insecure configurations. Finding vulnerabilities early allows the company to fix them before attackers exploit them.
3. Intrusion Detection System (IDS)	An IDS monitors network activity and alerts administrators when suspicious traffic or attack patterns are detected. It helps identify attempted breaches and unauthorized access.
4. User Account Reviews and Access Audits	Periodic reviews of employee accounts help identify inactive accounts, unnecessary permissions, and unauthorized access privileges. This reduces the risk of account misuse.
5. Email Security Monitoring	Email monitoring tools detect phishing messages, malicious attachments, and suspicious links before they reach employees. This helps reduce the likelihood of credential theft and ransomware infections.

3. Corrective Controls: Corrective controls help TechNova Solutions recover from cybersecurity incidents, restore normal operations, and prevent similar incidents from happening again.

Control	Why This Control Is Useful
1. Incident Response Plan	A documented incident response plan provides clear procedures for identifying, containing, investigating, and recovering from cyber incidents. It reduces confusion and helps minimize damage during emergencies such as ransomware attacks.
2. Regular Data Backups	Secure backups allow the organization to restore critical systems and customer data after ransomware, accidental deletion, or system failure. Offline backups reduce the risk of attackers encrypting backup files.
3. Disaster Recovery Plan (DRP)	A Disaster Recovery Plan (DRP) defines how the company will restore important services after major disruptions. It helps maintain business continuity and reduces downtime.
4. Patch Management Process	Regularly applying security updates fixes known vulnerabilities in operating systems, applications, and devices. This reduces the chance of attackers exploiting outdated software.
5. Post-Incident Review and Continuous Improvement	Reviewing incidents after recovery helps identify the root cause, evaluate response effectiveness, and improve security policies and controls. It supports the continuous improvement of the organization's Information Security Management System (ISMS).

Summary

The recommended controls provide a layered security approach for TechNova Solutions. Preventive controls reduce the likelihood of cyber incidents, detective controls improve the organization's ability to identify threats quickly, and corrective controls ensure effective recovery when incidents occur. Implementing these controls will improve cybersecurity maturity and support the company's goal of meeting enterprise customer security requirements.

Security Policies

To improve its cybersecurity maturity and prepare for enterprise customer requirements, TechNova Solutions should establish formal information security policies. These policies will provide clear security expectations, define employee responsibilities, and support the implementation of an Information Security Management System (ISMS) aligned with ISO/IEC 27001.

The following five policies are recommended:

Policy Name	Purpose	Who It Applies To	Why It Matters
1. Information Security Policy	Establishes the organization's overall commitment to protecting information assets, managing security risks, and maintaining the confidentiality, integrity, and availability of data.	All employees, contractors, managers, and third-party users who access company systems or information.	Provides the foundation for cybersecurity governance and demonstrates to enterprise customers that the company has a structured approach to managing information security.
2. Access Control Policy	Defines rules for creating, managing, reviewing, and removing user access to company systems such as Microsoft 365, GitHub, cloud storage, and business applications.	Employees, IT administrators, developers, managers, and contractors with access to company resources.	Reduces the risk of unauthorized access, insider threats, and misuse of sensitive customer and company information by enforcing the principle of least privilege.
3. Acceptable Use Policy	Defines appropriate use of company devices, internet access, email systems, software, and cloud services. It explains prohibited activities and employee security responsibilities.	All employees, remote workers, contractors, and temporary staff using company resources.	Helps prevent security incidents caused by unsafe behavior, such as downloading malicious software, sharing passwords, or accessing unauthorized websites.

4. Incident Response Policy	Establishes procedures for identifying, reporting, containing, investigating, and recovering from cybersecurity incidents such as ransomware, data breaches, and phishing attacks.	All employees, IT administrators, management, and incident response personnel.	Ensures the organization can respond quickly and effectively during security incidents, reducing financial losses, downtime, and reputational damage.
5. Data Protection and Privacy Policy	Defines requirements for collecting, storing, processing, sharing, and securely disposing of sensitive information, including customer and employee data.	Employees, developers, database administrators, finance staff, HR staff, and third parties handling company data.	Protects sensitive customer information, supports privacy obligations, and helps maintain customer trust when handling personal and payment information.

Summary

Implementing these policies will help TechNova Solutions establish stronger cybersecurity governance, improve employee accountability, and demonstrate security readiness to potential enterprise customers. These policies should be reviewed regularly, approved by management, communicated to employees, and updated as business and security requirements change.

Compliance Review

Introduction

TechNova Solutions develops web and mobile applications and processes customer data, including personal and payment information. Because it serves customers in Nigeria and Europe, the company must comply with relevant data protection and cybersecurity regulations. Compliance supports legal obligations, protects customer data, and builds trust with enterprise clients.

The following regulations and standards apply to TechNova Solutions:

Regulation / Standard	Why It Applies	Personal Data Protected	Business Impact of Failure to Comply
Nigeria Data Protection Act (NDPA) 2023	The NDPA applies because TechNova Solutions operates in Nigeria and processes personal data belonging to Nigerian customers, employees, and other individuals. The company collects and stores personal information through its applications and business systems.	Names, email addresses, phone numbers, employee information, identification details, financial information, and other information that can identify a person.	Non-compliance may result in regulatory investigations, financial penalties, legal claims, loss of customer confidence, reputational damage, and difficulty securing contracts with organizations requiring data protection compliance.
General Data Protection Regulation (GDPR)	GDPR applies because TechNova Solutions has customers in Europe and may process personal data belonging to European residents. It applies even to organizations outside the European Union when they provide services to or monitor individuals in the EU/EEA.	Names, email addresses, phone numbers, IP addresses, online identifiers, payment details, location information, employee records, and other personally identifiable information (PII).	Failure to comply may lead to significant fines, legal action, mandatory security improvements, loss of European customers, and rejection by enterprise clients requiring GDPR compliance.

Payment Card Industry Data Security Standard (PCI DSS)	PCI DSS applies if TechNova Solutions stores, processes, or transmits payment card information through its applications or payment systems. The company handles payment-related information and must ensure secure payment processing practices.	Payment card numbers, cardholder information, transaction records, and payment authentication information.	Non-compliance can result in payment processing restrictions, financial penalties from payment providers, increased risk of fraud, customer compensation costs, and damage to the company's reputation.
ISO/IEC 27001 Information Security Management System (ISMS)	ISO/IEC 27001 is a security management standard that helps organizations establish, operate, and continuously improve information security practices. It is highly relevant because TechNova Solutions wants to demonstrate security maturity before signing an enterprise contract.	Customer information, source code, employee records, financial information, business documents, and all other company-controlled information assets.	Without alignment to ISO/IEC 27001, enterprise customers may consider TechNova Solutions a higher-risk supplier, reducing business opportunities and making it harder to pass customer security reviews.

Conclusion

Compliance with Nigerian and European data protection requirements is essential for TechNova Solutions to maintain customer trust and qualify for enterprise partnerships. Failure to comply could create significant business risks, including financial penalties, legal exposure, reputational damage, and loss of future opportunities. By improving governance, implementing security controls, and aligning with ISO/IEC 27001 practices, TechNova Solutions can demonstrate a stronger cybersecurity posture and become a more reliable technology partner.

Internal Audit Checklist

This internal audit checklist is designed to evaluate TechNova Solutions' current cybersecurity posture, identify gaps in information security practices, and determine readiness for enterprise customer security requirements. The checklist is based on ISO/IEC 27001 information security management principles.

No.	Audit Question	Yes/No	Evidence/Comments
1	Has TechNova Solutions established a formal Information Security Policy approved by management?		
2	Has the company performed a formal information security risk assessment to identify cybersecurity risks?		
3	Is there a documented asset inventory identifying critical systems, applications, and information assets?		
4	Are asset owners assigned responsibility for protecting company information resources?		
5	Are user accounts created, modified, and removed through a formal access management process?		
6	Is Multi-Factor Authentication (MFA) enabled for Microsoft 365, GitHub, and other critical systems?		
7	Are user access permissions reviewed regularly to ensure employees only have necessary access?		
8	Are employee laptops protected with updated antivirus or Endpoint Detection and Response (EDR) solutions?		
9	Are operating systems and applications regularly updated with security patches?		
10	Are customer and employee sensitive data protected using encryption during storage and transmission?		
11	Are regular backups performed for critical business systems and customer information?		
12	Are backup copies protected from ransomware and regularly tested for restoration?		

13	Are security logs collected and reviewed for Microsoft 365, GitHub, applications, and network systems?		
14	Are employees provided with regular cybersecurity awareness training, including phishing awareness?		
15	Does the organization have a documented incident response plan for cybersecurity events?		
16	Are procedures established for reporting and managing personal data breaches?		
17	Does the company perform regular vulnerability assessments or security testing?		
18	Are third-party services such as Microsoft 365, GitHub, and cloud providers reviewed for security risks?		
19	Are cybersecurity policies reviewed and updated regularly to reflect business and technology changes?		
20	Does management regularly review cybersecurity performance and approve security improvement initiatives?		

Audit Review Outcome

The results of this checklist should be used to:

- Identify security gaps and compliance weaknesses.
- Prioritize cybersecurity improvement activities.
- Support ISO/IEC 27001 readiness efforts.
- Provide evidence of security maturity to potential enterprise customers.
- Improve the organization's overall risk management process.

A completed checklist should include supporting evidence such as policies, access reports, system configurations, training records, backup reports, vulnerability scan results, and incident response documentation.

Executive Summary

Overview

This Governance, Risk, and Compliance (GRC) assessment evaluated the cybersecurity posture of TechNova Solutions against the principles of ISO/IEC 27001. As the company prepares to secure an enterprise contract, strengthening its information security practices is essential to protect critical assets, meet regulatory requirements, and satisfy customer security expectations. The assessment found that while TechNova Solutions has a solid technical foundation, it lacks a formal Information Security Management System (ISMS), documented security policies, and dedicated security governance, increasing its exposure to cyber threats and compliance risks.

Key Risks

The most significant risks identified include ransomware attacks, phishing and credential theft, unauthorized access to sensitive information, data breaches leading to regulatory non-compliance, and weak security governance. These top five risks could result in operational disruption, financial losses, legal penalties, reputational damage, and reduced customer confidence.

Key Recommendations

To strengthen its cybersecurity posture, TechNova Solutions should implement an ISO/IEC 27001-aligned ISMS, enforce Multi-Factor Authentication (MFA) across critical systems, establish key security policies, provide regular cybersecurity awareness training, deploy endpoint protection, maintain secure offline backups, conduct vulnerability assessments and patch management, and implement formal incident response and disaster recovery processes.

Business Benefits

Implementing these recommendations will improve the organization's ability to prevent cyber incidents, protect customer and business information, and comply with regulations such as the Nigeria Data Protection Act (NDPA) and GDPR. It will also enhance customer trust, support business continuity, and increase the company's ability to meet enterprise security requirements and win future contracts.

Next Steps

Over the next 6–12 months, TechNova Solutions should establish an ISMS, perform a detailed security gap analysis, implement core security policies, strengthen access controls, conduct regular risk assessments, improve backup and disaster recovery capabilities, deliver mandatory security awareness training, and perform periodic internal audits and management reviews to ensure continuous improvement.

Conclusion

TechNova Solutions is well positioned to improve its cybersecurity maturity before entering into an enterprise customer agreement. By implementing the recommendations in this report, the company can better protect its information assets, meet regulatory and contractual expectations, reduce cybersecurity risks, and build long-term trust with customers and business partners.